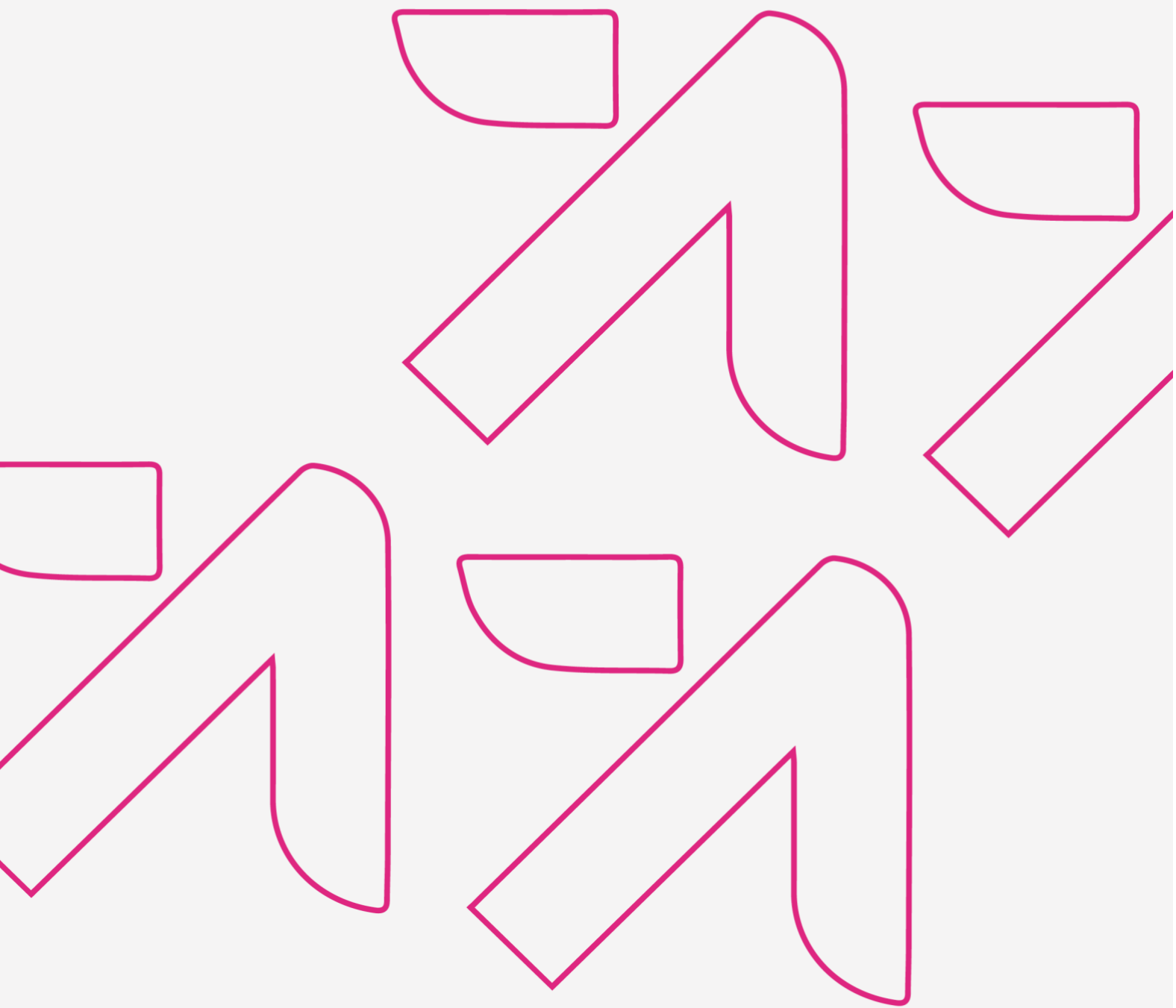




Máster de

Ciberseguridad Hacking Ético

[Módulo Bastionado de Redes y Sistemas]

Curso académico 2026/2027 - Edición Presencial

UT2. Arquitecturas de red seguras

Encaje en el curso 2026/2027: esta unidad desarrolla el RA4 (diseñar redes seguras, temas 6 y 7) y adelanta el perímetro del RA5 (tema 8).

1. Objetivo de una arquitectura segura

El propósito de una arquitectura de red segura es garantizar que los sistemas y servicios estén aislados, controlados y protegidos mediante capas sucesivas de seguridad. No se trata de “poner un firewall y ya está”, sino de diseñar una estructura donde cada componente tenga funciones claras, límites bien definidos y rutas de comunicación estrictamente necesarias.

Una red segura reduce superficie de ataque, limita movimientos laterales y dificulta que un incidente escale.

2. Principios básicos de diseño seguro

2.1. Mínima exposición

Solo se exponen a Internet los servicios que deben ser accesibles externamente. Todo lo demás permanece detrás de firewalls y filtros.

2.2. Mínimo privilegio entre segmentos

Los servicios se comunican únicamente con los recursos necesarios. No existe “acceso total a todo”.

2.3. Separación de funciones

Servicios críticos no coexisten en el mismo segmento de red. Ejemplo: servidores web separados de bases de datos, gestión separada del tráfico de producción.

2.4. Defensa en profundidad

La seguridad se construye por capas: firewalls, ACLs, segmentación, autenticación, cifrado, monitorización.

3. Segmentación de red

La segmentación divide la red en zonas lógicas separadas, cada una con reglas de acceso propias.

3.1. Tipos de segmentos

- **Red de usuarios:** equipos personales, oficinas, WiFi corporativa.
- **Red de servidores internos:** servicios internos no accesibles desde Internet.
- **DMZ:** zona expuesta donde se ubican servicios públicos.

- **Red de administración:** usada únicamente por personal técnico.
- **Red de invitados:** WiFi aislado sin acceso a recursos internos.
- **Red OT/IoT:** dispositivos industriales o IoT aislados del resto.

Ejemplo de plan de segmentación

Zona	VLAN	Red	Quién vive ahí
Usuarios	10	10.10.10.0/24	Puestos de trabajo
Servidores internos	20	10.10.20.0/24	Ficheros, ERP, bases de datos
DMZ	30	10.10.30.0/24	Web pública, proxy inverso
Administración	40	10.10.40.0/27	Equipos de salto y consolas de gestión
Invitados	50	192.168.50.0/24	Wifi de visitas (solo Internet)
IoT / OT	60	10.10.60.0/24	Impresoras, cámaras, sensores

El tamaño de cada red se ajusta a lo que necesita: una red de administración con 30 direcciones es más fácil de vigilar que una /16 donde cabe cualquier cosa.

3.2. Beneficios

- Contención de incidentes.
- Menor superficie expuesta.
- Control granular de tráfico.
- Movimientos laterales mucho más difíciles.

4. VLANs y separación lógica

Las VLAN permiten crear múltiples redes virtuales dentro del mismo hardware.

Usos típicos

- Separar usuarios de servidores.
- Aislar trabajo remoto, invitados o IoT.
- Segmentar tramos de producción y desarrollo.

Buenas prácticas

- Etiquetar VLANs según función, no nombres genéricos.
- Evitar VLAN planas donde todo comunica con todo.
- Configurar VLANs restringidas para administración.

5. Firewalls y reglas de control

5.1. Firewall perimetral

Filtra acceso entre Internet y la organización. Debe permitir solo tráfico imprescindible hacia servicios públicos (ej. HTTPS).

5.2. Firewall interno

Controla acceso entre segmentos. Es donde se aplican reglas de comunicación mínimas.

5.3. Reglas recomendadas

- “Deny all” por defecto.
- Permitir solo puertos y orígenes necesarios.
- Registrar tráfico denegado en logs para análisis.
- Revisar reglas periódicamente para eliminar excepciones obsoletas.

5.4. Más allá del filtrado por puerto

Un firewall clásico decide por IP y puerto. Los de nueva generación (**NGFW**) identifican además la aplicación y el usuario, e integran prevención de intrusiones (**IPS**). Delante de las aplicaciones web se añade un **WAF**, que entiende HTTP y frena inyecciones o abusos que un filtro por puerto deja pasar porque «el 443 está permitido».

6. DMZ (zona desmilitarizada)

La **DMZ** es una zona intermedia entre Internet y la red interna.

Ubicación típica

- Servidores web públicos.
- Servidores de correo entrante.
- Proxies inversos.
- APIs expuestas.

Funcionamiento

Internet → DMZ → Red Interna

Nunca se comunica Internet → Red Interna directamente. Y un detalle que se olvida a menudo: la DMZ tampoco debe poder iniciar conexiones libremente hacia la red interna; solo los flujos concretos que necesite (por ejemplo, la web hacia su base de datos).

7. Microsegmentación

La microsegmentación divide la red en segmentos extremadamente pequeños, a veces por servicio o aplicación.

Ventajas clave

- Aislamiento total entre servicios.
- Reglas de acceso hipergranulares.
- Limitación extrema del movimiento lateral.
- Más útil en entornos cloud y contenedores.

Ejemplos típicos

- Un contenedor solo puede hablar con la base de datos en su puerto concreto.
- Un servidor web no puede comunicarse con servidores internos que no usa.
- Un equipo infectado no puede desplazarse a otros segmentos.

8. Zero Trust aplicado a la arquitectura

Zero Trust se basa en “no confiar en nada, verificar todo”. Es un modelo moderno aplicado sobre arquitecturas clásicas.

Principios fundamentales

- No existe “red interna segura”.
- Cada solicitud requiere verificación de identidad, dispositivo y contexto.
- Acceso just-in-time y just-enough.
- Limitación total de la confianza implícita.

Aplicación real

- Autenticación fuerte en todos los accesos.
- Segmentación + microsegmentación.
- Políticas basadas en identidad, no en IP.
- Monitorización continua.

Zero Trust y acceso remoto

La VPN tradicional mete al usuario «dentro» de la red y, una vez dentro, ve mucho más de lo que necesita. El acceso de red de confianza cero (**ZTNA**) publica solo la aplicación concreta, después de comprobar identidad, estado del dispositivo y contexto en cada conexión. La referencia del modelo es NIST SP 800-207.

9. Definición de flujos de comunicación

Una arquitectura segura define qué comunica con qué, en qué puerto y en qué dirección.

Ejemplo de flujo mínimo

- Web (DMZ) → Base de datos (interno) solo por 3306/TCP.

- Usuario → Proxy corporativo → Internet.
- Equipo de admin → Red de gestión → Servidores (SSH/RDP).
- Invitados → Internet (sin tocar la red interna).

Matriz de flujos

La forma más clara de documentarlo es una tabla. Todo lo que no aparece en ella está denegado.

Origen	Destino	Puerto	Motivo
Internet	Proxy inverso (DMZ)	443/TCP	Web pública
Web (DMZ)	Base de datos (servidores)	3306/TCP	Consultas de la aplicación
Usuarios	Servidor de ficheros	445/TCP	Carpetas compartidas
Administración	Servidores y DMZ	22/TCP, 3389/TCP	Gestión
Invitados	Internet	80, 443/TCP	Navegación

Errores típicos a evitar

- Permisos globales “ANY ANY”.
- Dejar tráfico lateral sin control en redes planas.
- No separar tráfico de administración del de producción.

10. Documentación de la arquitectura

Documentar de forma clara evita errores y facilita auditorías.

Elementos esenciales

- Diagrama actualizado de red.
- Subredes y VLANs con propósito definido.
- Mapa de flujos permitidos y bloqueados.
- Tabla de puertos y protocolos.
- Zonas críticas marcadas.
- Políticas asociadas: acceso, administración, backups, logging.

La documentación debe mantenerse viva y revisarse tras cada cambio en la infraestructura.

Para ampliar

- NIST SP 800-207: Zero Trust Architecture.
- Guías CCN-STIC de la serie 800 sobre arquitecturas de seguridad e interconexión en el ENS.

- CIS Controls v8, controles 12 y 13: gestión y defensa de la infraestructura de red.